

AUTOM8ION LAB

NIST AI RISK MANAGEMENT FRAMEWORK

COMPLIANCE AUDIT & IMPLEMENTATION CHECKLIST

AI RMF 1.0 — Full Lifecycle Audit Guide

Govern · Map · Measure · Manage

Version 1.0 | Autom8ion Lab Internal Use | 2025

HOW TO USE THIS DOCUMENT

This audit guide operationalizes the NIST AI Risk Management Framework (AI RMF 1.0) into a step-by-step compliance checklist for Autom8ion Lab and client engagements. Each of the four core functions — GOVERN, MAP, MEASURE, and MANAGE — is broken down into auditable actions, evidence requirements, and ownership assignments.

Use this document to:

1. Conduct an internal AI risk audit before deploying any AI system
2. Assess client AI environments during discovery and onboarding
3. Build a defensible risk posture for enterprise and regulated clients
4. Demonstrate security-first AI implementation standards
5. Prepare for client audits, vendor reviews, and compliance inquiries

HIGH RISK

Immediate remediation required.
Document gap, assign owner, set
30-day deadline.

MEDIUM RISK

Address within 60-90 days. Track in risk
register with interim controls noted.

LOW / COMPLIANT

Compliant or low exposure. Document
evidence, schedule next review cycle.

SECTION 1 — FRAMEWORK OVERVIEW

What is the NIST AI Risk Management Framework?

The NIST AI RMF (published January 2023) is a voluntary framework developed by the National Institute of Standards and Technology to help organizations identify, assess, and manage the risks and trustworthiness of AI systems throughout their entire lifecycle. It is applicable to any organization that develops, deploys, or uses AI — regardless of size, industry, or technical sophistication.

Unlike a rigid compliance standard, the AI RMF is structured around four interconnected core functions: GOVERN, MAP, MEASURE, and MANAGE. These functions work together to create a repeatable, documented process for responsible AI use.

Why This Matters for Autom8ion Lab

As an AI implementation firm, Autom8ion Lab is accountable not just for what gets built — but for the risk posture it creates in client environments. The AI RMF provides the structure to:

- Demonstrate a security-first approach to every AI deployment
- Protect clients from liability tied to unmanaged AI risk
- Differentiate from agencies that ship AI without governance infrastructure
- Support clients in regulated industries (finance, healthcare, legal, government)
- Create a repeatable, auditable delivery standard

Framework Structure at a Glance

Phase	Core Function	Primary Purpose	Key Outcome
1	GOVERN	Establish organizational culture, accountability, and policies for AI risk management	Policies, roles, training, and governance structures in place
2	MAP	Identify and categorize AI systems and their associated risks in context	AI inventory and risk classification complete
3	MEASURE	Analyze and assess identified risks using metrics and evaluation methods	Risk severity quantified and prioritized
4	MANAGE	Treat, respond to, and monitor AI risks with documented controls	Risk treated, monitored, and response plans active

SECTION 2 — GOVERN FUNCTION

01

GOVERN

GOVERN

Establish the organizational foundation for responsible AI. This is not optional or administrative overhead — it is the infrastructure that makes every other function credible and enforceable.

GOVERN 1 — Policies, Processes, and Procedures

Establish documented policies that define how AI risk is identified, managed, and reviewed at the organizational level.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G1.1	Develop and document an official AI Risk Management Policy that references NIST AI RMF 1.0 as the governing standard	Leadership	Signed policy document with version date	☐ Open
G1.2	Define the scope of AI systems covered by the policy — including third-party tools, APIs, and automated workflows deployed in client environments	Operations	Scope statement within policy	☐ Open
G1.3	Establish a review and update cycle for all AI risk policies (minimum: annual, recommended: semi-annual)	Leadership	Policy with review cadence noted	☐ Open
G1.4	Document an escalation path for AI risk incidents — who is notified, when, and what actions are triggered	Operations	Escalation matrix or runbook	☐ Open
G1.5	Ensure all AI-related policies are legally reviewed for liability exposure and compliance alignment in client jurisdictions	Legal/Leadership	Legal sign-off record	☐ Open

GOVERN 2 — Accountability and Roles

Assign clear ownership of AI risk management functions. Unassigned accountability is the most common failure point in AI governance.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G2.1	Designate a named AI Risk Owner (internal role) responsible for oversight of all AI deployments and risk decisions	<i>Leadership</i>	Named individual in org chart or RACI	☐ Open
G2.2	Create a RACI matrix covering all AI lifecycle activities: development, deployment, monitoring, incident response, client handoff	<i>Operations</i>	RACI document or equivalent	☐ Open
G2.3	Identify and document all internal staff and contractors who interact with AI systems — including access levels and responsibilities	<i>Operations/HR</i>	Team access register	☐ Open
G2.4	Establish accountability for client-facing AI systems — who owns the risk post-deployment in each engagement	<i>Client Services</i>	Contract clause + internal handoff doc	☐ Open
G2.5	Document the process for removing or transitioning AI risk accountability when personnel change	<i>HR/Operations</i>	Offboarding/transition procedure	☐ Open

GOVERN 3 — Workforce and Culture

Governance fails when it is policy-only. Staff and stakeholders must understand their role in managing AI risk and have the knowledge to act on it.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G3.1	Conduct AI risk awareness training for all staff who build, configure, or manage AI systems — document completion	<i>HR/Operations</i>	Training records with dates	☐ Open
G3.2	Ensure technical staff understand the specific failure modes of AI systems they work with (hallucination, data poisoning, model drift, adversarial inputs)	<i>Technical Lead</i>	Training content + sign-off	☐ Open
G3.3	Train client-facing staff on how to communicate AI risk transparently without creating liability exposure	<i>Client Services</i>	Communication guidelines or training	☐ Open
G3.4	Establish a clear process for staff to raise AI risk concerns without penalty — a de facto AI risk reporting channel	<i>Leadership</i>	Reporting mechanism documented	☐ Open

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G3.5	Document that leadership has reviewed and endorsed the AI risk culture expectations across the organization	Leadership	Leadership sign-off or board memo	☐ Open

GOVERN 4 — Organizational Risk Tolerance

Define what level of AI risk is acceptable before deployment. Risk tolerance must be explicit — ambiguity here creates inconsistent decisions downstream.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G4.1	Define organizational risk tolerance for AI systems across impact categories: safety, fairness, security, privacy, operational continuity	Leadership	Risk tolerance statement in policy	☐ Open
G4.2	Establish different risk thresholds for high-risk vs. low-risk AI use cases — document what triggers enhanced review	Leadership/ Ops	Risk classification criteria	☐ Open
G4.3	Define the organizational position on deploying AI in high-stakes domains (healthcare, legal, financial decisions, physical safety)	Leadership	Written position or sector policy	☐ Open
G4.4	Document how client risk tolerance is assessed during onboarding and how it shapes the system design and controls deployed	Client Services	Client intake questionnaire with risk section	☐ Open

GOVERN 5 — Vendor and Third-Party AI Risk

AI systems often depend on third-party models, platforms, and APIs. The risk does not transfer with the vendor relationship — it stays with the deployer.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G5.1	Maintain a vendor register of all third-party AI tools, LLM APIs, and automation platforms used in internal operations or client deployments	Operations	Vendor register with last review date	☐ Open

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
G5.2	Review vendor AI risk disclosures, model cards, and security documentation before use in client environments	<i>Technical Lead</i>	Vendor review log	☐ Open
G5.3	Include AI-specific terms in vendor contracts: data handling, model behavior, incident notification, audit rights	<i>Legal/Leadership</i>	Contract clauses review	☐ Open
G5.4	Establish a process to re-evaluate vendors when model versions, terms of service, or data practices change	<i>Operations</i>	Vendor review trigger procedure	☐ Open
G5.5	Document what happens to client data processed by third-party AI vendors — retention, deletion, and data residency	<i>Technical/Legal</i>	Data flow diagram + DPA records	☐ Open

SECTION 3 — MAP FUNCTION

02

MAP

MAP

Identify every AI system in scope, understand its context and purpose, and classify the risks it introduces. You cannot manage what you have not mapped.

MAP 1 — AI System Identification and Inventory

Create a complete and current inventory of all AI systems — internal and client-facing. This is the foundation of the entire risk management process.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
M1.1	Create and maintain a formal AI System Inventory listing every AI system in use: name, purpose, vendor/model, deployment environment, and date of first use	Operations	AI system inventory register	[] Open
M1.2	Include all client-deployed AI systems in the inventory with clear linkage to client account and engagement scope	Client Services	Client AI system register	[] Open
M1.3	Identify shadow AI — staff or clients using AI tools not officially approved or tracked — and bring them into governance scope	Operations	Shadow AI discovery process documented	[] Open
M1.4	Classify each AI system by type: generative AI, predictive model, automation workflow, decision-support system, or hybrid	Technical Lead	Type classification in inventory	[] Open
M1.5	Document all AI system integrations — which systems connect to each other, what data flows between them, and what APIs are used	Technical Lead	Integration map or data flow diagram	[] Open
M1.6	Conduct inventory refresh quarterly or after any new AI deployment	Operations	Inventory audit log with dates	[] Open

MAP 2 — Risk Context and Use Case Classification

Each AI system operates in a specific business context. Risk is not abstract — it is tied to who uses the system, what decisions it influences, and what happens when it fails.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
M2.1	For each AI system, document its primary use case and the business process it supports or replaces	<i>Operations/Technical</i>	Use case description per system	[] Open
M2.2	Identify the end users of each AI system — internal staff, clients, client customers, automated processes — and document user profile	<i>Operations</i>	User profile documentation	[] Open
M2.3	Assess whether each AI system influences consequential decisions: hiring, credit, healthcare, legal, safety-critical outcomes	<i>Technical/Legal</i>	Decision impact assessment per system	[] Open
M2.4	Classify each AI system by risk level: High (consequential decisions, regulated domains), Medium (operational automation), Low (internal productivity tools)	<i>Leadership/Technical</i>	Risk classification register	[] Open
M2.5	Document the intended vs. actual use of each AI system — flag any drift or scope creep from original deployment intent	<i>Operations</i>	Use-case drift log or review record	[] Open

MAP 3 — Stakeholder and Impact Mapping

AI systems do not just affect users — they affect affected populations, third parties, and downstream stakeholders who may never interact directly with the system.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
M3.1	Identify all direct stakeholders for each AI system: those who operate it, those who receive its outputs, those who rely on its decisions	<i>Operations</i>	Stakeholder map per AI system	[] Open
M3.2	Identify affected populations — groups that may be impacted by AI system outputs without directly interacting with the system	<i>Technical/Legal</i>	Affected population assessment	[] Open
M3.3	Assess potential for disparate impact — whether the AI system could produce different outcomes across demographic groups	<i>Technical Lead</i>	Bias and fairness assessment	[] Open
M3.4	Document client-side stakeholders in all client engagements: who signed off on AI use, who is	<i>Client Services</i>	Client stakeholder register per engagement	[] Open

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
	operationally responsible, who represents end-user interests			
M3.5	Identify regulatory bodies or compliance frameworks that govern AI use in the client's industry and document applicability to deployed systems	<i>Legal/Leadership</i>	Regulatory applicability matrix	[] Open

MAP 4 — Data and Training Risk Mapping

AI systems are only as trustworthy as the data they are built on. This step surfaces data-layer risks before they become operational problems.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
M4.1	Document the data sources used to train, fine-tune, or populate each AI system — including data origin, collection method, and consent basis	<i>Technical Lead</i>	Data lineage documentation	[] Open
M4.2	Assess whether training or operational data contains personally identifiable information (PII) and confirm GDPR/CCPA/applicable compliance	<i>Technical/Legal</i>	PII assessment and compliance note	[] Open
M4.3	Identify potential biases in training data that could produce discriminatory or inaccurate outputs at scale	<i>Technical Lead</i>	Data bias review record	[] Open
M4.4	Document data access controls — who can read, modify, or delete data used by AI systems	<i>Technical Lead</i>	Access control documentation	[] Open
M4.5	Map client data that flows into AI systems during deployments — document what is processed, stored, and retained by third-party AI vendors	<i>Technical/Legal</i>	Client data flow map + DPA	[] Open
M4.6	Assess data quality: completeness, accuracy, timeliness, and representativeness of data used to inform AI outputs	<i>Technical Lead</i>	Data quality assessment report	[] Open

SECTION 4 — MEASURE FUNCTION

03

MEASURE

MEASURE

Quantify and evaluate the risks identified in MAP. Move from awareness to evidence. Measurement creates the defensible record that makes risk management credible — to clients, auditors, and regulators.

MEASURE 1 — Risk Assessment Methodology

Define how risks are evaluated. Without a consistent methodology, risk assessments are subjective and impossible to compare, track, or defend.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME1.1	Document the risk assessment methodology used: likelihood x impact scoring, qualitative rating scales, or quantitative models — and apply consistently	Technical/Ops	Risk methodology document	[] Open
ME1.2	Define risk categories assessed for every AI system: safety, security, fairness/bias, privacy, transparency, operational reliability, legal/regulatory	Leadership/Technical	Risk category definitions	[] Open
ME1.3	Complete a formal risk assessment for every AI system in the inventory using the documented methodology	Technical Lead	Risk assessment records per system	[] Open
ME1.4	Assign severity ratings to each identified risk: Critical, High, Medium, Low — with defined criteria for each level	Technical/Ops	Severity rating criteria + per-system ratings	[] Open
ME1.5	Prioritize risks for treatment based on severity, likelihood, and business impact — document prioritization rationale	Leadership/Ops	Prioritized risk register	[] Open

MEASURE 2 — Performance and Reliability Testing

AI systems must be tested against failure modes before deployment and monitored for degradation after. Document all testing — it is your evidence of due diligence.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME2.1	Conduct pre-deployment testing for every AI system: accuracy benchmarking, edge case evaluation, and stress testing under expected load	Technical Lead	Test plans and results	[] Open
ME2.2	Test AI system outputs for consistency, accuracy, and reliability across diverse input conditions — including adversarial and out-of-distribution inputs	Technical Lead	Robustness test records	[] Open
ME2.3	Test for hallucination and confabulation in generative AI systems — document the rate and severity under deployment conditions	Technical Lead	Hallucination test results	[] Open
ME2.4	Evaluate model behavior under degraded input quality — assess whether the system fails gracefully or produces confident incorrect outputs	Technical Lead	Degraded input test results	[] Open
ME2.5	Document the performance baselines established during testing — these become the reference point for ongoing monitoring	Technical Lead	Baseline performance metrics	[] Open
ME2.6	For client deployments, conduct user acceptance testing (UAT) with client stakeholders before full production rollout	Client Services	UAT sign-off documentation	[] Open

MEASURE 3 — Bias, Fairness, and Equity Evaluation

Bias in AI systems creates legal exposure, reputational damage, and real harm to real people. Evaluate it explicitly — not as a checkbox, but as a risk category with measurable impact.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME3.1	Define fairness criteria for each AI system based on its use case — document what constitutes equitable treatment of different user groups	Technical/Legal	Fairness criteria document per system	[] Open
ME3.2	Test AI outputs across demographic and contextual subgroups to identify differential performance or disparate impact	Technical Lead	Subgroup testing results	[] Open
ME3.3	Document the results of bias evaluations and any identified disparities — including whether they fall within acceptable thresholds	Technical Lead	Bias evaluation report	[] Open

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME3.4	Where bias or disparate impact is identified, document the remediation plan — retraining, filtering, human review, or system redesign	Technical/Operations	Remediation plan with timeline	☐ Open
ME3.5	Assess whether any bias found in the AI system creates legal liability under applicable anti-discrimination laws (EEOC, FCRA, fair lending, etc.)	Legal	Legal review record	☐ Open

MEASURE 4 — Security and Adversarial Risk Evaluation

AI systems introduce attack surfaces that traditional security frameworks do not fully cover. Evaluate AI-specific threats explicitly and document the controls applied.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME4.1	Conduct prompt injection testing for all LLM-based systems — document attack scenarios tested and system behavior observed	Technical Lead	Prompt injection test log	☐ Open
ME4.2	Test for data exfiltration risk — can user inputs or adversarial prompts cause the AI to reveal training data, system prompts, or confidential information?	Technical Lead	Exfiltration test results	☐ Open
ME4.3	Assess model inversion and membership inference risk — especially for systems fine-tuned on sensitive client data	Technical Lead	Privacy attack assessment	☐ Open
ME4.4	Evaluate supply chain risk: have the underlying model providers, APIs, and infrastructure providers been vetted for security posture?	Technical/Operations	Supply chain security review	☐ Open
ME4.5	Test for denial-of-service vulnerabilities — can the AI system be overwhelmed, manipulated into infinite loops, or forced into excessive compute consumption?	Technical Lead	DoS resilience test results	☐ Open
ME4.6	Document all identified security vulnerabilities in the AI security risk register with severity rating, status, and assigned owner	Technical Lead	AI security risk register	☐ Open

MEASURE 5 — Transparency and Explainability Assessment

AI systems that cannot be explained cannot be trusted. Assess whether decisions made by or through the AI can be audited, challenged, and understood by stakeholders.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
ME5.1	Document what the AI system can and cannot explain about its outputs — and whether explainability is required for the use case	Technical Lead	Explainability assessment per system	[] Open
ME5.2	For systems influencing consequential decisions, confirm whether outputs include interpretable reasoning, confidence scores, or supporting evidence	Technical Lead	Output transparency review	[] Open
ME5.3	Assess whether affected users have a right to explanation under applicable law (GDPR Art. 22, CCPA, AI Act provisions) and document compliance posture	Legal	Legal right-to-explanation analysis	[] Open
ME5.4	Document how system prompts, configuration parameters, and fine-tuning data are protected from disclosure while maintaining auditability	Technical Lead	IP and prompt protection documentation	[] Open

SECTION 5 — MANAGE FUNCTION

04

MANAGE

MANAGE

Act on identified and measured risks. Deploy controls, monitor for new risks, and build the operational capability to respond when AI systems behave unexpectedly or cause harm.

MANAGE 1 — Risk Treatment and Control Implementation

Every risk in the register must have a treatment decision: accept, mitigate, transfer, or avoid. Document the rationale — silence is not a strategy.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG1.1	For each risk in the risk register, assign a treatment decision: Accept (with documented rationale), Mitigate (with controls), Transfer (insurance/contract), or Avoid (system not deployed)	<i>Leadership/Ops</i>	Risk register with treatment decisions	[] Open
MG1.2	Implement technical controls for mitigated risks: guardrails, output filters, rate limits, human review gates, access restrictions, monitoring hooks	<i>Technical Lead</i>	Control implementation log	[] Open
MG1.3	Implement procedural controls: human-in-the-loop requirements, approval workflows, override capabilities, and escalation triggers for AI decisions	<i>Operations</i>	Workflow documentation with controls	[] Open
MG1.4	Document the residual risk remaining after controls are applied — confirm it falls within organizational risk tolerance	<i>Technical/Ops</i>	Residual risk assessment	[] Open
MG1.5	Obtain formal sign-off from the designated AI Risk Owner before deploying any AI system rated High risk	<i>Leadership</i>	Deployment authorization record	[] Open
MG1.6	For client deployments, obtain documented client acceptance of residual risks before go-live	<i>Client Services</i>	Client risk acceptance sign-off	[] Open

MANAGE 2 — Ongoing Monitoring and Model Drift Detection

AI risk does not end at deployment. Model drift, data shift, and environmental changes can degrade system performance and introduce new risks over time.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG2.1	Implement continuous or periodic monitoring for all production AI systems — track output quality, performance metrics, and anomaly indicators	<i>Technical Lead</i>	Monitoring setup documentation	[] Open
MG2.2	Define and document model drift thresholds — the performance degradation levels that trigger review or retraining	<i>Technical Lead</i>	Drift thresholds in monitoring config	[] Open
MG2.3	Monitor for data distribution shift — changes in the input data characteristics that the model was not trained on	<i>Technical Lead</i>	Data drift monitoring records	[] Open
MG2.4	Schedule and conduct regular AI system reviews: quarterly for medium-risk, monthly for high-risk systems	<i>Technical/Ops</i>	Review schedule and completed review logs	[] Open
MG2.5	Monitor vendor and third-party AI system updates — assess impact of version changes, model updates, and policy changes on deployed systems	<i>Technical Lead</i>	Vendor change log and impact assessments	[] Open
MG2.6	Maintain a log of all AI system incidents, anomalies, and near-misses — regardless of severity	<i>Operations</i>	AI incident log	[] Open

MANAGE 3 — Incident Response for AI Systems

When an AI system causes harm, behaves unexpectedly, or is exploited — the response must be fast, documented, and controlled. Build this capability before you need it.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG3.1	Develop an AI-specific Incident Response Plan covering: detection, containment, investigation, remediation, communication, and post-incident review	<i>Operations/Technical</i>	AI Incident Response Plan document	[] Open
MG3.2	Define what constitutes an AI incident requiring activation of the response plan — include clear triggering criteria by severity level	<i>Operations</i>	Incident classification criteria	[] Open
MG3.3	Establish the capability to suspend or disable any AI system within a documented timeframe — and test this capability before it is needed	<i>Technical Lead</i>	Kill switch / suspension test record	[] Open

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG3.4	Define notification obligations for AI incidents involving client data, regulatory exposure, or consequential harm — know who must be told and by when	<i>Legal/Leadership</i>	Notification matrix and timeline	[] Open
MG3.5	Conduct post-incident reviews within 5 business days of any significant AI incident — document root cause, impact, and preventive actions	<i>Operations</i>	Post-incident review records	[] Open
MG3.6	Test the incident response plan with a tabletop exercise at least annually — document results and incorporate improvements	<i>Operations</i>	Tabletop exercise record	[] Open

MANAGE 4 — Human Oversight and Override Mechanisms

No AI system should operate without a defined level of human oversight. The degree of oversight should be proportional to the risk level and consequences of the system's decisions.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG4.1	Define the human oversight model for each AI system: human-in-the-loop (decision approval), human-on-the-loop (monitoring with override), or human-out-of-the-loop (fully automated, low-risk only)	<i>Technical/Operations</i>	Oversight model definition per system	[] Open
MG4.2	Implement and document override capabilities for all AI systems — the ability for a human to reject, modify, or countermand AI outputs	<i>Technical Lead</i>	Override mechanism documentation	[] Open
MG4.3	For high-risk AI use cases, require documented human review before AI recommendations are acted upon — create an approval workflow	<i>Operations</i>	Approval workflow records	[] Open
MG4.4	Train all staff operating AI systems on when and how to override AI outputs — overrides must be easy to execute under time pressure	<i>Operations/HR</i>	Override training records	[] Open
MG4.5	Log all human overrides of AI decisions — analyze override patterns to identify systemic AI system failures or miscalibrations	<i>Technical Lead</i>	Override log with analysis	[] Open

MANAGE 5 — Decommissioning and End-of-Life Management

AI systems that are no longer in use still carry risk. Data retention, model access, and residual outputs must be managed through end-of-life.

ID	Audit Action / Checklist Item	Owner	Evidence Required	Status
MG5.1	Define decommissioning criteria for AI systems — triggers that initiate system retirement: performance degradation, policy change, client off-boarding, or vendor discontinuation	<i>Technical/Operations</i>	Decommissioning criteria document	[] Open
MG5.2	Document the decommissioning process: data deletion, access revocation, API key rotation, model artifact deletion, and third-party notification	<i>Technical Lead</i>	Decommissioning checklist and log	[] Open
MG5.3	For client deployments, document data destruction or return obligations and obtain client sign-off upon decommissioning	<i>Client Services/Legal</i>	Data destruction certificate or record	[] Open
MG5.4	Ensure decommissioned AI system documentation (risk assessments, incident logs, test results) is retained per document retention policy	<i>Operations</i>	Archive record with retention period	[] Open

SECTION 6 — AUDIT SCORING, SUMMARY, AND NEXT STEPS

Audit Scoring Methodology

Score each checklist item as one of the following. Calculate a compliance percentage per function and overall to establish your current AI RMF posture.

Score	Status	Definition	Next Action
2	COMPLIANT	Evidence exists, control is active, documented and current	Document in register, schedule next review
1	PARTIAL	Work begun but incomplete, evidence insufficient or not current	Define gap, assign owner, set 30-day completion date
0	NON-COMPLIANT	No action taken, no evidence exists, not in scope yet	Treat as risk item, assign owner, escalate if high-risk
N/A	NOT APPLICABLE	Item does not apply to this AI system or engagement	Document rationale for exclusion in risk register

Audit Summary Scorecard

Complete this table after scoring all checklist items. Use it as the executive summary for internal governance reviews and client-facing reporting.

Function	Total Items	Compliant (2)	Partial (1)	Non-Compliant (0)	Score %	RAG
GOVERN (24 items)	___	___	___	___	___%	[]
MAP (24 items)	___	___	___	___	___%	[]
MEASURE (24 items)	___	___	___	___	___%	[]
MANAGE (24 items)	___	___	___	___	___%	[]
OVERALL SCORE	96 items	___	___	___	___%	[]

Score Interpretation: 90-100% = Strong posture, schedule next cycle | 70-89% = Acceptable, address partials within 60 days | 50-69% = Significant gaps, prioritize High risk items immediately | Below 50% = Critical remediation required before any new AI deployments

Priority Remediation Tracker

Log the top 10 highest-priority items from the audit. Assign owners, set deadlines, and review weekly until resolved.

Item ID	Description of Gap	Risk Level	Owner	Due Date	Status
1					[] Open
2					[] Open
3					[] Open
4					[] Open
5					[] Open
6					[] Open
7					[] Open
8					[] Open
9					[] Open
10					[] Open

SECTION 7 — IMPLEMENTATION ROADMAP

Phased Implementation Plan

Use this roadmap to move from audit to active compliance. The phases are sequenced by dependency — you cannot effectively MAP risks without GOVERN infrastructure in place.

Phase	Timeframe	Key Activities	Success Criteria
1	Days 1-14	Conduct full audit using this checklist. Score all 96 items. Identify all High-risk gaps. Assign AI Risk Owner. Brief leadership on findings.	Audit complete. Risk register populated. Leadership briefed.
2	Days 15-30	Remediate all Critical and High-risk gaps. Develop AI Risk Management Policy. Build AI System Inventory. Assign RACI.	Policy signed. Inventory complete. High-risk gaps closed or mitigated.
3	Days 31-60	Complete MAP function: full system classification, data mapping, stakeholder analysis. Begin MEASURE: baseline testing and bias evaluation for all active systems.	All active AI systems assessed. Baselines documented.
4	Days 61-90	Implement MANAGE controls: monitoring, incident response plan, human oversight models, vendor reviews. Close remaining Medium-risk gaps.	Controls active. IRP tested. All Medium gaps addressed.
5	Ongoing	Quarterly audit cycle. Continuous monitoring. Incident log review. Annual policy refresh. New deployment reviews before go-live.	Compliance score maintained above 85%. Zero unmanaged High risks.

Audit Completion Sign-Off

Audit Conducted By	AI Risk Owner Sign-Off	Leadership Authorization
Name: _____	Name: _____	Name: _____

Role: _____ _____	Role: _____ _____	Role: _____ _____
Date: _____ _____	Date: _____ _____	Date: _____ _____
Signature: _____ _____	Signature: _____ _____	Signature: _____ _____

AUTOM8ION LAB — CONFIDENTIAL

This document is proprietary to Autom8ion Lab. It is intended for internal use and authorized client engagements only.

NIST AI RMF 1.0 Compliance Audit | Version 1.0 | 2025 | autom8ionlab.com